To Whom It May Concern

April 20, 2026

Subject: **Acceptance of Penetration Test Deliverables and Recommendation of Testers**

To Whom It May Concern,

This letter formally accepts the penetration testing engagement conducted against the LearningNuggets adaptive cybersecurity tutoring platform from March 30 through April 6, 2026, and records ListenToSee, Inc.'s recommendation of the three testers who performed the work under signed Penetration Testing Agreements dated March 30, 2026: [redacted] and Anthony Stumpf.

The engagement covered the platform's AI tutor and LLM layer, its containerized lab environments, and the full application and infrastructure surface of [redacted] and the associated backend services. Each tester operated within the scope, rules of engagement, confidentiality terms, and reporting protocol set out in their agreement.

Engagement Outcomes

The delivered Full Report dated April 10, 2026 documented ten findings — one Critical, four Medium, one Low, and four Informational — together with two LLM adversarial assessments and twelve security controls confirmed as functioning as designed. The Critical finding (V-001) identified a Supabase Row-Level Security misconfiguration that permitted any authenticated user to self-escalate to administrator via the public REST endpoint; a companion Medium finding (V-002) allowed free-tier subscription bypass through the same mechanism. Both were demonstrated end-to-end with a reproducible exploit sequence and precise remediation guidance.

All Critical and Medium findings, together with the in-scope Low finding applicable to immediate remediation, have since been closed. Supabase migration 055 applied column-level REVOKEs and a block_self_privileged_mutation trigger; the profile route received a server-side shape validator as defense-in-depth against the stored-XSS candidate; and the remaining admin endpoint was migrated to the apiHandler wrapper. Empirical verification completed on April 17, 2026. The remaining Low item (V-006, CAPTCHA enforcement via the direct Supabase auth endpoint) is tracked as a dashboard-configuration follow-up within the 90-day SLA the report contemplates.

I accept all deliverables as meeting the form, detail, and timeliness that the reporting clause of each agreement contemplates. The Critical finding was escalated within the 24-hour window the agreement requires; notes, captures, and artifacts were handled in accordance with the confidentiality provisions; and no real student data was accessed during testing.

Professional Conduct and Technical Quality

The testers demonstrated disciplined scoping, clean reporting, and sound technical judgment throughout. Reconnaissance and enumeration were thorough; the AI and LLM adversarial battery exercised sixteen distinct jailbreak and injection vectors against the tutor persona, all of which the platform withstood; the application-layer findings were accompanied by the exact request path, the policy gap, and the steps needed to reproduce and remediate. Communication with the platform team was professional and timely at every point in the engagement.

Recommendation

On the strength of this engagement, I recommend [redacted] and Anthony Stumpf for future penetration testing work. Their findings materially improved the security posture of the LearningNuggets platform before broader student deployment, and their conduct throughout was consistent with the standards I expect of senior offensive-security practitioners. I am available by phone or email to any organization considering them for similar engagements.

Warm regards,

Scott Young
President, ListenToSee, Inc.